UNIVERSITI TEKNOLOGI MARA
MARKING SCHEME

COURSE	:	COMPUTER SECURITY
COURSE CODE	:	CSC662
EXAMINATION	:	OCTOBER 2026 (MOCK)
TIME	:	3 HOURS

MARKING SCHEME NOTES

1. This marking scheme accompanies the CSC662 mock paper (October 2026). Computed answers show working; theory answers are supported by lecture slides (not lecturer-marked) with a verbatim quote and slide citation.

2. Supported theory marking points quote the lecture decks; any unresolved slot would remain a visible placeholder.

3. Part A = 10 x (2 + 6); Part B = 2 x (5 + 5); total = 100 marks.

4. Computed: 3 slot(s). Supported theory: 19 slots. Placeholders: 2.
Questions and answers are for local study use only.

5. Near-copy rejection used all 35 past papers; style widening is recorded per slot.

FOR MARKERS' USE ONLY

This marking scheme consists of 13 printed pages

© Hak Cipta Universiti Teknologi MARA

CSC662 - MARKING SCHEME (MOCK OCTOBER 2026)

Labels: computed / supported by lecture slides (not lecturer-marked) / placeholder. No official marking scheme exists for the real CSC662 papers; this is generated for the mock.

Entailment labels: supported = the quote directly supports the marking point (or the point passed the stem-overlap gate without an LLM check); partly supported = the quote supports part of the point or is ambiguous; not supported = the quote does not support the point. Only 'not supported' points triggered regeneration.

Part A: 10 x (2 + 6) = 80 marks. Part B: 2 x (5 + 5) = 20 marks. Total: 100 marks. Slots: 3 computed, 19 supported by lecture slides, 2 placeholder.

Methods: computed answers use verified solvers. Theory answers are supported by lecture slides (not lecturer-marked). Each marking point carries a verbatim quote, a deck/slide/chunk citation and a term-overlap score; low overlap is flagged for human review. Sources are restricted to the slot topic's allowed decks, and a slide is not reused across questions where an alternative exists.

PART A - QUESTION 1

A1a - 2 marks - computed - matches lecture slides 5-9 (Caesar shift 3 examples)

Question:

Using Caesar Cipher technique, decrypt the following ciphertext with a shift of 7 (replace each letter with the one 7 positions to the left).
KLCPJLYLABYULKHUKDPWLKVUL

Answer: DEVICERETURNEDANDWIPEDONE

Working:

```
K (10) -7 mod 26 -> D
L (11) -7 mod 26 -> E
C ( 2) -7 mod 26 -> V
P (15) -7 mod 26 -> I
J ( 9) -7 mod 26 -> C
L (11) -7 mod 26 -> E
Y (24) -7 mod 26 -> R
L (11) -7 mod 26 -> E
A ( 0) -7 mod 26 -> T
B ( 1) -7 mod 26 -> U
Y (24) -7 mod 26 -> R
U (20) -7 mod 26 -> N
L (11) -7 mod 26 -> E
K (10) -7 mod 26 -> D
H ( 7) -7 mod 26 -> A
U (20) -7 mod 26 -> N
K (10) -7 mod 26 -> D
D ( 3) -7 mod 26 -> W
P (15) -7 mod 26 -> I
W (22) -7 mod 26 -> P
L (11) -7 mod 26 -> E
K (10) -7 mod 26 -> D
V (21) -7 mod 26 -> O
U (20) -7 mod 26 -> N
L (11) -7 mod 26 -> E
```

Suggested marks: 1 mark for identifying the cipher/shift direction; 1 mark for the complete plaintext.
Confidence: computed - matches lecture slides 5-9 (Caesar shift 3 examples).

A1b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

State six facts about substitution ciphers as presented in the lecture, covering what the cipher does to plaintext letters, what serves as the key, the resulting output, the Shannon principle it corresponds to, and where the idea is applied today.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment

1	The cipher works by swapping each plain-text letter for a different letter.	"In substitution ciphers, we replace the plain-text letters with other letters"	031 - Classical Cryptography, slide 4	031 - Classical Cryptography::s0 4::1	0.67	supported (ste gate)
2	The text produced after the replacement is called the cipher-text.	"The resulting text is the cipher-text"	031 - Classical Cryptography, slide 4	031 - Classical Cryptography::s0 4::1	0.33 LOW	supported
3	The rule used to perform the substitution acts as the key.	"The substitution rule is the key"	031 - Classical Cryptography, slide 4	031 - Classical Cryptography::s0 4::1	0.50	supported (ste gate)
4	This substitution mechanism maps onto Shannon's confusion principle.	"Corresponds to Shannon's principle of confusion"	031 - Classical Cryptography, slide 4	031 - Classical Cryptography::s0 4::1	0.43 LOW	supported
5	The same substitution concept carries over into contemporary cipher designs.	"This idea is used in modern ciphers"	031 - Classical Cryptography, slide 4	031 - Classical Cryptography::s0 4::1	0.11 LOW	supported
6	Vigenere's polyalphabetic scheme extends the Caesar shift cipher.	"Vigenere's polyalphabetic cipher (19th century) generalizes Caesar's shift cipher"	031 - Classical Cryptography, slide 14	031 - Classical Cryptography::s1 4::1	0.71	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 031 - Classical Cryptography, slide 14; 031 - Classical Cryptography, slide 4

PART A - QUESTION 2

A2a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

List two facts about transposition ciphers as described in the lecture, covering how the rail fence cipher arranges plain-text and what serves as its key.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The rail fence cipher writes the plain-text in a zigzag pattern across rows and then reads letters off row by row to form the cipher-text.	"The plain-text is written in a zigzag pattern in rows and form the cipher-text by reading off the letters from the rows."	031 - Classical Cryptography, slide 25	031 - Classical Cryptography::s2 5::1	0.67	supported (ste gate)
2	The key of a rail fence cipher is a positive integer giving the number of rows.	"The key for a rail fence cipher is a positive integer that represents the size of rows."	031 - Classical Cryptography, slide 25	031 - Classical Cryptography::s2 5::1	0.86	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 031 - Classical Cryptography, slide 25

A2b - 6 marks - computed - matches lecture slide 15 (standard tableau)

Question:

Decrypt the following ciphertext using the Vigenere cipher with the key CIPHER. Use the standard 26 x 26 Vigenere tableau, writing the key over the message and repeating it as necessary.
UMRBVVNWVPREQE

Answer: SECURELOGINNOW

The 26 x 26 Vigenere tableau is printed in the question paper.

Working:

```
Standard 26 x 26 tableau, A=0; key repeated over the ciphertext.
Ciphertext: UMRBVVNWVPREQE
Key:        CIPHERCIPHERCI
```

```
Letter-by-letter: C - K mod 26 = P
  U (20) - C ( 2) = 18 -> S
  M (12) - I ( 8) =  4 -> E
  R (17) - P (15) =  2 -> C
  B ( 1) - H ( 7) = 20 -> U
  V (21) - E ( 4) = 17 -> R
  V (21) - R (17) =  4 -> E
  N (13) - C ( 2) = 11 -> L
  W (22) - I ( 8) = 14 -> O
  V (21) - P (15) =  6 -> G
  P (15) - H ( 7) =  8 -> I
  R (17) - E ( 4) = 13 -> N
  E ( 4) - R (17) = 13 -> N
  Q (16) - C ( 2) = 14 -> O
  E ( 4) - I ( 8) = 22 -> W
Plaintext:  SECURELOGINNOW
```

Suggested marks: 1 mark for the key/table setup; 4 marks for the letter-by-letter working; 1 mark for the complete answer.

Confidence: computed - matches lecture slide 15 (standard tableau).

PART A - QUESTION 3

A3a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

List the stages that make up the identification stage and the authentication stage of a biometric authentication process.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The identification stage begins with acquisition of the biometric sample.	"Identification Stage Acquisition Creation of Master characteristics"	072 - Biometrics and Authentication, slide 5	072 - Biometrics and Authentication::s05::1	0.50	supported (ste gate)
2	The identification stage also includes storing the master characteristics.	"Creation of Master characteristics Storage of Master characteristics"	072 - Biometrics and Authentication, slide 5	072 - Biometrics and Authentication::s05::1	0.17 LOW	supported

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.

Citations: 072 - Biometrics and Authentication, slide 5

A3b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Refer to your answer in (a). Based on the scenario in (a), discuss the biometric mechanisms and technologies used for authentication. Your discussion should cover the definition of a biometric, the two categories of biometric applications, and specific technologies with their characteristics.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A biometric is defined as a physiological or behavioural characteristic of a human being that can distinguish one person from another and can theoretically be used for identification or verification of identity.	"A biometric is a physiological or behavioural characteristic of a human being that can distinguish one person from another and that theoretically can be used for identification or verification of identity."	072 - Biometrics and Authentication, slide 2	072 - Biometrics and Authentication::s02::1	0.92	supported (ste gate)
2	Biometric applications are categorized into two sectors: psychological (physiological) and behavioural.	"Biometric applications available today are categorized into 2 sectors"	072 - Biometrics and Authentication, slide 4	072 - Biometrics and Authentication::s04::1	0.62	supported (ste gate)
3	The psychological category includes iris,	"Psychological: Iris, Fingerprints, Hand, Retinal and Face	072 - Biometrics and	072 - Biometrics and	0.78	supported (ste gate)

© Hak Cipta Universiti Teknologi MARA

	fingerprints, hand, retinal and face recognition.	recognition"	Authentication, slide 4	Authentication::s04::1		
4	The behavioural category includes voice, typing pattern and signature.	"Behavioural: Voice, Typing pattern, Signature"	072 - Biometrics and Authentication, slide 4	072 - Biometrics and Authentication::s04::1	0.67	supported (ste gate)
5	Retinal scanning is very efficient and cannot be spoofed, but has disadvantages such as the user having to look directly, a high FTE ratio, acceptability concerns, light exposure and hygiene.	"Very efficient - cant be spoofed!"	072 - Biometrics and Authentication, slide 9	072 - Biometrics and Authentication::s09::1	0.14 LOW	partly supporte
6	Iris scanning scans a unique pattern of the iris, requires no touch, and overcomes retinal scanner issues, although contact lenses may be an issue.	"Scans unique pattern of iris"	072 - Biometrics and Authentication, slide 10	072 - Biometrics and Authentication::s10::1	0.29 LOW	partly supporte

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 072 - Biometrics and Authentication, slide 10; 072 - Biometrics and Authentication, slide 2; 072 - Biometrics and Authentication, slide 4; 072 - Biometrics and Authentication, slide 9

PART A - QUESTION 4

A4a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain the Chinese Wall model as a formal security model, covering the policy it implements and how its access rules behave over time.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The Chinese Wall is a confidentiality access control policy (not an integrity policy) that addresses conflicts of interest.	"Strictly speaking, this is not an integrity policy, but an access control confidentiality policy."	024 - Formal Security Model, slide 21	024 - Formal Security Model::s21::1	0.55	supported (ste gate)
2	Access rights change dynamically because they depend on the subject's history of past accesses.	"Notice that permissions change dynamically. The access rights that any subject enjoys depends on the history of past accesses"	024 - Formal Security Model, slide 24	024 - Formal Security Model::s24::1	0.80	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 024 - Formal Security Model, slide 21; 024 - Formal Security Model, slide 24

Status: computed placeholder - no question generated for this type.

PART A - QUESTION 5

A5a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain the difference between morals, ethics and laws as they apply to the conduct of a computing professional.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Morals are described as	"Morals are traditions of belief	071 - Ethics and	071 - Ethics and	0.55	supported (ste

© Hak Cipta Universiti Teknologi MARA

	traditions of belief concerning right and wrong conduct, forming the basis of social behaviour.	about right and wrong conduct"	Computer Security, slide 5	Computer Security::s05::1		gate)
2	Laws are formal rules of conduct imposed by a sovereign authority such as a government on its subjects or citizens.	"Laws are formal rules of conduct that a sovereign authority, such as a government, imposes on its subjects or citizens"	071 - Ethics and Computer Security, slide 5	071 - Ethics and Computer Security::s05::1	1.00	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 071 - Ethics and Computer Security, slide 5

A5b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

State six professional conduct requirements that the ACM code places on a computing professional, covering both how they carry out their work and how they treat the public and the systems they build.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A professional must aim for high quality in the processes and products of their professional work.	"Strive to achieve high quality in both the processes and products of professional work."	071 - Ethics and Computer Security, slide 12	071 - Ethics and Computer Security::s12::1	0.75	supported (ste gate)
2	A professional must keep up high standards of competence, conduct and ethical practice.	"Maintain high standards of professional competence, conduct, and ethical practice."	071 - Ethics and Computer Security, slide 12	071 - Ethics and Computer Security::s12::1	0.78	supported (ste gate)
3	A professional must only perform work in areas where they are competent.	"Perform work only in areas of competence."	071 - Ethics and Computer Security, slide 12	071 - Ethics and Computer Security::s12::1	0.56	supported (ste gate)
4	A professional must give thorough evaluations of computer systems and their impacts, including possible risks.	"Give comprehensive and thorough evaluations of computer systems and their impacts, including analysis of possible risks."	071 - Ethics and Computer Security, slide 12	071 - Ethics and Computer Security::s12::1	0.80	supported (ste gate)
5	A professional must contribute to society and human well-being, recognising that all people are stakeholders in computing.	"Contribute to society and to human well-being, acknowledging that all people are stakeholders in computing."	071 - Ethics and Computer Security, slide 11	071 - Ethics and Computer Security::s11::1	0.73	supported (ste gate)
6	A professional must respect privacy and honour confidentiality.	"Respect privacy. Honor confidentiality."	071 - Ethics and Computer Security, slide 11	071 - Ethics and Computer Security::s11::1	0.50	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 071 - Ethics and Computer Security, slide 11; 071 - Ethics and Computer Security, slide 12

PART A - QUESTION 6

A6a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

State TWO (2) typical locations where IDS sensors are placed in a network-based IDS architecture.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A sensor can be	"Just inside the firewall"	062 - Intrusion	062 - Intrusion	0.50	supported (ste

	positioned just inside the firewall.		Detection System, slide 7	Detection System::s07::1		gate)
2	A sensor can be positioned on the DMZ.	"On the DMZ"	062 - Intrusion Detection System, slide 7	062 - Intrusion Detection System::s07::1	0.25 LOW	supported

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 062 - Intrusion Detection System, slide 7

A6b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Describe six (6) preventive network security mechanisms and the protection each provides, as covered in the network security lecture.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A firewall controls incoming and outgoing network traffic according to predetermined security policies.	"Control incoming and outgoing traffic on network with predetermined security policies."	061 - Network Security, slide 3	061 - Network Security::s03::1	0.80	supported (ste gate)
2	A proxy server improves data security and network performance by acting as a firewall and web filter, sharing connections and caching data.	"Proxy servers act as a firewall and web filter, provide shared network connections, and cache data to speed up common requests."	061 - Network Security, slide 3	061 - Network Security::s03::1	0.79	supported (ste gate)
3	Network segmentation creates boundaries between segments whose computing assets share a common function, risk or role.	"Boundaries between network segments where computing assets within the segment have a common function, risk or role within an organization."	061 - Network Security, slide 3	061 - Network Security::s03::1	0.77	supported (ste gate)
4	A remote access VPN gives individual hosts or clients remote and secure access to an organization's network.	"Provides remote and secure access to an organization network to individual hosts or clients"	061 - Network Security, slide 4	061 - Network Security::s04::1	0.89	supported (ste gate)
5	Zero Trust Network Access (ZTNA) restricts a user to only the access and permissions needed to fulfil the role.	"A user should only has access and permission that required to fulfill the role"	061 - Network Security, slide 4	061 - Network Security::s04::1	0.50	supported (ste gate)
6	Intrusion detection/prevention systems detect or prevent attacks such as brute force, denial-of-service and exploitation of network vulnerabilities.	"To detect or prevent the network security attacks such as brute force attacks, Denial-of-Service attacks and exploits of network vulnerabilities."	061 - Network Security, slide 4	061 - Network Security::s04::1	0.85	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 061 - Network Security, slide 3; 061 - Network Security, slide 4

PART A - QUESTION 7

A7a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

State TWO (2) points about software insecurity and buffer overflows as described in the Software Security lecture.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Software insecurity arises because attackers can alter resources that are critical for program execution, such as the instruction pointer or function call addresses.	"Software insecurity stems from attacker's ability to modify system resources criticial for program execution, e.g. instruction pointer, function call addresses, interrupt addresses, etc."	051 - Software Security, slide 30	051 - Software Security::s30::1	0.65	supported (ste gate)
2	A buffer overflow occurs when, lacking proper bound checking, buffer content spills into adjacent higher stack memory and lets an attacker overwrite the return address to hijack execution flow.	"Without proper bound checking a buffer content can overspill into adjacent upper stack area."	051 - Software Security, slide 21	051 - Software Security::s21::1	0.35 LOW	partly supporte

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 051 - Software Security, slide 21; 051 - Software Security, slide 30

A7b - 6 marks - PLACEHOLDER

Topic: software/OS security; command: Explain
Status: placeholder - no supported question passed verification.
Reason: A7b point 1: marking point is a verbatim copy of its quote; phrase the point as an answer requirement, not as copied slide text

PART A - QUESTION 8

A8a - 2 marks - PLACEHOLDER

Topic: access control models; command: State
Status: placeholder - no supported question passed verification.
Reason: A8a: sub-angle not followed; use one of ['acl', 'acm', 'capability', 'access control list', 'matrix']

A8b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

*Discuss the goals of access control and the role of the reference monitor in authorization, and explain how the Chinese Wall model's simple security rule and *-property constrain access over time. Provide six distinct points.*

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	State that access control aims to grant, limit, prevent, and revoke access.	"Goals of access control: Granting access Limiting access Preventing access Revoking access"	023 - Access Control and Authorization, slide 4	023 - Access Control and Authorization::s04::1	0.86	supported (ste gate)
2	Explain that the reference monitor is the component that makes authorization decisions.	"Reference monitor makes authorization decisions."	023 - Access Control and Authorization, slide 4	023 - Access Control and Authorization::s04::1	1.00	supported (ste gate)
3	Note that reference monitors realize access control policies and can be deployed at all levels of the system hierarchy.	"Reference monitors are instruments for realization of access control policies. They can be deployed at all levels of system hierarchy."	023 - Access Control and Authorization, slide 18	023 - Access Control and Authorization::s18::1	0.92	supported (ste gate)
4	Describe the Chinese Wall simple security rule: access is granted only if the object is within the same company dataset already accessed or in	"A subject s can be granted access to an object o only if the object: is in the same company datasets as the objects already accessed by s, that is, "within the Wall," or belongs to an entirely different conflict of interest class."	024 - Formal Security Model, slide 25	024 - Formal Security Model::s25::1	0.77	supported (ste gate)

	a different conflict of interest class.					
5	Explain the Chinese Wall *-property: write access requires simple-rule permission and no read access to unsanitized information in a different company dataset.	"Write access is only permitted if: access is permitted by the simple security rule, and no object can be read which is: in a different company dataset than the one for which write access is requested, and contains unsanitized information."	024 - Formal Security Model, slide 26	024 - Formal Security Model::s26::1	0.64	supported (ste gate)
6	State that the Chinese Wall is an access control policy whose accesses depend on the history of past accesses.	"The Chinese Wall is an access control policy in which accesses are sensitive to the history of past accesses."	024 - Formal Security Model, slide 27	024 - Formal Security Model::s27::1	0.78	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 023 - Access Control and Authorization, slide 18; 023 - Access Control and Authorization, slide 4; 024 - Formal Security Model, slide 25; 024 - Formal Security Model, slide 26; 024 - Formal Security Model, slide 27

PART A - QUESTION 9

A9a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain two password security controls that can be applied to password files and accounts to strengthen authentication.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Access control should be applied to the password files themselves.	"Access control applied to password files"	022 - Identification and Authentication, slide 12	022 - Identification and Authentication::s12::1	0.57	supported (ste gate)
2	Accounts should be de-activated after multiple failed login attempts.	"De-activation of accounts after multiple failed logins"	022 - Identification and Authentication, slide 12	022 - Identification and Authentication::s12::1	0.75	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 022 - Identification and Authentication, slide 12

A9b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain how single sign-on and Kerberos-based authentication mechanisms reduce the burden of password management for users in a large distributed environment, and describe the role of smart cards as an alternative authentication mechanism.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Single sign-on reduces the need for users to memorize multiple passwords.	"Reduce the need to memorize passwords"	022 - Identification and Authentication, slide 16	022 - Identification and Authentication::s16::1	0.50	supported (ste gate)
2	Single sign-on reduces the time users spend typing passwords.	"Reduce the time spent on typing passwords"	022 - Identification and Authentication, slide 16	022 - Identification and Authentication::s16::1	0.43 LOW	supported
3	Single sign-on lowers the effort required to maintain passwords.	"Reducing password maintenance effort"	022 - Identification and	022 - Identification and Authentication::s1	0.29 LOW	supported

© Hak Cipta Universiti Teknologi MARA

			Authentication, slide 16	6::1		
4	Kerberos is a client-server architecture that provides single sign-on.	"Client-server architectures (Kerberos, Active Directory)"	022 - Identification and Authentication, slide 16	022 - Identification and Authentication::s16::1	0.57	supported (ste gate)
5	In Kerberos login, the user enters a user name and password at the client workstation.	"User enters his user name, U and password, P at a client workstation."	022 - Identification and Authentication, slide 19	022 - Identification and Authentication::s19::1	0.71	supported (ste gate)
6	The hash of the user's password becomes the secret key of the client.	"The hash value of his password KU = h(P) becomes a secret key of the client/user."	022 - Identification and Authentication, slide 19	022 - Identification and Authentication::s19::1	1.00	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 022 - Identification and Authentication, slide 16; 022 - Identification and Authentication, slide 19

PART A - QUESTION 10

A10a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain two characteristics of Trojan horses as a type of malware, including how they present themselves and what harm they cause once active.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Trojan horses disguise themselves as useful or benign programs so users install them unsuspectingly.	"They usually masquerade as helpful or harmless programs"	051 - Software Security, slide 12	051 - Software Security::s12::1	0.10 LOW	supported
2	Once running, a Trojan steals private data, deletes files, logs keystrokes, or opens a way for additional malware.	"begin to steal private data, delete files, log keystrokes or provide an opening for further malware to get installed"	051 - Software Security, slide 12	051 - Software Security::s12::1	0.64	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 051 - Software Security, slide 12

A10b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain six techniques by which malware such as viruses and worms propagate themselves or attach their code to a host program, and describe how early malware demonstrated these propagation methods.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A virus can propagate by appending its body to a host program and saving the original entry point inside the virus body.	"Append a virus body to a program Save an entry point to a program in a virus body"	051 - Software Security, slide 9	051 - Software Security::s09::1	0.58	supported (ste gate)
2	A virus can replace the program entry point with a jump to the virus body, and the virus code later restores the original entry point and jumps to it.	"Replace a program entry point with a jump to a virus body Virus code restores the original entry point and jumps to it after its own execution"	051 - Software Security, slide 9	051 - Software Security::s09::1	0.83	supported (ste gate)
3	For EXE files, a virus	"Over write a program header to	051 - Software	051 - Software	0.67	supported (ste

	can overwrite the program header so that the entry point switches to the virus, and then jump to the original entry point during execution.	switch the entry point to a virus Jump to the original entry point during execution"	Security, slide 10	Security::s10::1		gate)
4	The Morris worm propagated across the Arpanet by exploiting a debugging feature of sendmail that allowed remote execution.	"Used a debugging feature of sendmail (remote execution) Propagated in the Arpanet"	051 - Software Security, slide 7	051 - Software Security::s07::1	0.55	supported (ste gate)
5	Elk Cloner spread through boot sector infection and hooked the reset handler so that a poem was played on every fiftieth reset.	"A program spread via boot sector infection On every 50-th reset a short poem was is played by hooking the reset handler"	051 - Software Security, slide 7	051 - Software Security::s07::1	0.71	supported (ste gate)
6	The Brain virus was included in the boot sector of distributed software diskettes, which is how it spread in the wild.	"Included in a boot sector of distributed software diskettes"	051 - Software Security, slide 7	051 - Software Security::s07::1	0.60	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 051 - Software Security, slide 10; 051 - Software Security, slide 7; 051 - Software Security, slide 9

PART B - QUESTION 1

B1a - 5 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain five ways in which threat classes and malware can impact the confidentiality, integrity and availability of an information system, giving a distinct impact for each.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Disclosure threats such as snooping, sniffing and wiretapping give unauthorised access to information, harming confidentiality.	"Disclosure - unauthorized access to information"	011 - Introduction to Computer Security, slide 10	011 - Introduction to Computer Security::s10::1	0.27 LOW	partly supporte
2	Deception threats involve acceptance of false data, which damages integrity.	"Deception - acceptance of false data"	011 - Introduction to Computer Security, slide 10	011 - Introduction to Computer Security::s10::1	0.50	supported (ste gate)
3	Usurpation threats give unauthorised control of part of a system and are countered by availability services.	"Usurpation - unauthorized control of some part of a system"	011 - Introduction to Computer Security, slide 10	011 - Introduction to Computer Security::s10::1	0.44 LOW	partly supporte
4	Spyware steals user logins and passwords, so sensitive bank information can be compromised.	"They steal user logins and passwords, document sites visited, log keystrokes and even redirect browsers to unwanted sites."	051 - Software Security, slide 13	051 - Software Security::s13::1	0.40 LOW	partly supporte
5	Rootkits hide malicious processes and software so that the infected computer stays under the malware author's control.	"Rootkits are a type of malware that mask malicious processes and software in the infected systems to ensure privileged remote access."	051 - Software Security, slide 13	051 - Software Security::s13::1	0.50	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.

© Hak Cipta Universiti Teknologi MARA

Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 011 - Introduction to Computer Security, slide 10; 051 - Software Security, slide 13

B1b - 5 marks - supported by lecture slides (not lecturer-marked)

Question:

The Samy worm spread through MySpace by exploiting a cross-site scripting flaw. Explain five aspects of this case: how the malicious script was injected, how the worm gathered and added friends, how infection spread to visitors, how the script reached the browser, and the eventual scale of the outbreak.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The worm injected JavaScript into a user profile by writing to document.body.innerHTML.	"Inject Javascript into a user profile using document.body.innerHTML"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.70	supported (ste gate)
2	It obtained the list of the user's heroes by issuing a GET request on a user profile.	"Get the list of user's heros by using a GET on a user profile"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.43 LOW	supported
3	It added Samy as a friend by performing an XML-HTTP request on the addFriends page.	"Add Samy as a field by performing XML-HTTP on the addFriends page"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.78	supported (ste gate)
4	Any user visiting an infected user's page had their own profile and friends list infected with the JavaScript.	"Any user who visits an infected user's page will gets profile infected with Javascript and his friends list infected with Samy"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.70	supported (ste gate)
5	The outbreak eventually infected about 1,000,000 MySpace profiles.	"Eventually about 1,000,000 MySpace profiles were infected."	052 - Web Security, slide 15	052 - Web Security::s15::1	0.71	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 052 - Web Security, slide 15

PART B - QUESTION 2

B2a - 5 marks - supported by lecture slides (not lecturer-marked)

Scenario:

A hospital wants every workstation to prove at boot that it is running only approved software before it is allowed to access patient records. The IT team is told to base the design on the Trusted Platform Module and a chain of trust, and to explain the components involved.

Question:

State the role of the Trusted Platform Module in a trusted platform, and explain how a chain of trust is built from the hardware up to the running software, naming the stages involved and the roots of trust that support it.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The TPM is described as tamper-resistant hardware fitted into the platform.	"a tamper-resistant hardware module mounted in a platform"	073 - Trusted Computing, slide 6	073 - Trusted Computing::s06::1	0.57	supported (ste gate)
2	The TPM's duties are listed as measurement, protected storage, integrity reporting and policy enforcement.	"Responsible for: measurement, (protected) storage, (integrity) reporting and policy enforcement."	073 - Trusted Computing, slide 6	073 - Trusted Computing::s06::1	0.78	supported (ste gate)
3	In the chain of trust, each stage measures and validates the stage that follows it.	"Each stage measures and validates the next one"	073 - Trusted Computing, slide 8	073 - Trusted Computing::s08::1	0.50	supported (ste gate)

© Hak Cipta Universiti Teknologi MARA

4	The measurements taken are recorded in the TPM's Platform Configuration Registers.	"Measurements go into Platform Configuration Registers (PCRs) on the TPM"	073 - Trusted Computing, slide 8	073 - Trusted Computing::s08::1	0.71	supported (ste gate)
5	The chain begins at the hardware TPM and proceeds through the RTM, TPM software stack, BIOS and kernel, ending with the whole platform verified as trusted.	"The chain starts with the hardware TPM, then software: RTM,TPM Software Stack, BIOS, kernel"	073 - Trusted Computing, slide 8	073 - Trusted Computing::s08::1	0.50	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 073 - Trusted Computing, slide 6; 073 - Trusted Computing, slide 8

B2b - 5 marks - supported by lecture slides (not lecturer-marked)

Question:

Referring to the scenario, discuss the NGSCB/Nexus components that the IT team could use to enforce the approved-software requirement, covering the role of Nexus, the role of the Nexus Computing Agent, and how these components relate to the TPM.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Nexus is described as a security kernel that is authenticated on boot.	"Security kernel, authenticated on boot"	073 - Trusted Computing, slide 14	073 - Trusted Computing::s14::1	0.80	supported (ste gate)
2	Nexus authenticates trusted programs.	"Authenticates trusted programs"	073 - Trusted Computing, slide 14	073 - Trusted Computing::s14::1	0.75	supported (ste gate)
3	Nexus provides the application interface to the TPM.	"Application interface to TPM"	073 - Trusted Computing, slide 14	073 - Trusted Computing::s14::1	0.60	supported (ste gate)
4	The Nexus Computing Agent is a trusted software component.	"Trusted software component"	073 - Trusted Computing, slide 15	073 - Trusted Computing::s15::1	0.40 LOW	supported
5	The NCA runs in a trusted mode that communicates with Nexus.	"Runs in trusted mode that communicates with Nexus"	073 - Trusted Computing, slide 15	073 - Trusted Computing::s15::1	0.83	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 073 - Trusted Computing, slide 14; 073 - Trusted Computing, slide 15

End of marking scheme.

© Hak Cipta Universiti Teknologi MARA